
DATA PROCESSING AGREEMENT

PROCESSOR

Trackingplan Europe S.L.

CONTROLLER

[_____]

VERSION

2.0 — Draft for legal review, August 2026

GOVERNING LAW

Kingdom of Spain

Supersedes the previous Trackingplan Inc. DPA upon adoption.

INTRODUCTION

This Data Processing Agreement (“DPA”) forms part of, and is an addendum to, the agreement or general terms (“Terms of Service”) governing the services (the “Services”) provided by **Trackingplan Europe S.L.**, Plaza Nueva 18, 3º, 03300 Orihuela (Alicante), Spain, VAT ESB10937548 (“Trackingplan” or the “Processor”), to the customer identified in the applicable order or Terms of Service (the “Controller”).

This DPA applies whenever the Controller’s intended use of the Services triggers the application of Data Protection Laws. In providing the Services, Trackingplan processes Personal Data on behalf of the Controller, acting as a processor (or “service provider”).

1. DEFINITIONS

“**Data Protection Laws**” means all applicable laws relating to data protection and privacy, including: (a) the EU General Data Protection Regulation (Regulation (EU) 2016/679) (“GDPR”); (b) the UK General Data Protection Regulation and the Data Protection Act 2018, in each case as amended by the Data (Use and Access) Act 2025 (together, the “UK GDPR”); (c) the California Consumer Privacy Act of 2018, as amended by the California Privacy Rights Act of 2020 (“CCPA”); (d) other applicable US state privacy laws, including the Virginia Consumer Data Protection Act, the Colorado Privacy Act and the Connecticut Data Privacy Act; and (e) any other applicable national implementing legislation.

“**Personal Data**”, “**Processing**”, “**Controller**”, “**Processor**”, “**Data Subject**”, “**Personal Data Breach**” and “**Supervisory Authority**” have the meanings given to them in the applicable Data Protection Laws. Where the CCPA applies, “Controller” includes “business”, “Processor” includes “service provider”, and “Personal Data” includes “personal information”.

“**Sub-processor**” means any third party engaged by the Processor to process Personal Data on behalf of the Controller.

2. SCOPE OF PROCESSING

2.1 The subject matter, duration, nature and purpose of the Processing, the categories of Personal Data and the categories of Data Subjects are described in **Annex I**. The Processor shall process Personal Data solely as necessary to provide the Services and as described in this DPA, and for no other purpose.

2.2 **Special categories.** The Controller warrants that it will not submit to the Services any data revealing health, sex life or sexual orientation, racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade-union membership, nor genetic or biometric data. Accordingly, the Services will not knowingly store or process such data.

3. CONTROLLER OBLIGATIONS

The Controller warrants that: (a) it has obtained all necessary consents, provided all necessary notices, and otherwise has a lawful basis to have Personal Data processed by the Processor under this DPA; (b) its instructions to the Processor will comply with Data Protection Laws; and (c) it will provide the Processor with accurate and complete information regarding the Processing.

4. PROCESSING INSTRUCTIONS

4.1 The Processor shall process Personal Data only on documented instructions from the Controller, including with regard to transfers of Personal Data to a third country or an international organisation, unless required to do otherwise by applicable law; in such a case, the Processor shall inform the Controller of that legal requirement before processing, unless that law prohibits it on important grounds of public interest. This DPA, the Terms of Service and the Controller's configuration of the Services constitute the Controller's complete documented instructions; additional instructions require mutual written agreement.

4.2 The Processor may exercise reasonable technical discretion in routine operational matters (such as infrastructure maintenance, security updates and backup operations) provided such actions do not alter the nature, scope or purposes of the Processing.

4.3 The Processor shall immediately inform the Controller if, in its opinion, an instruction infringes Data Protection Laws.

5. CONFIDENTIALITY AND PERSONNEL

5.1 The Processor shall ensure that access to Personal Data is limited to personnel who need it to provide the Services, and that all such persons have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality, with obligations surviving the end of their engagement.

5.2 All personnel with access to Personal Data receive data-protection and information-security training at onboarding and at least annually thereafter.

5.3 The Processor shall ensure that any natural person acting under its authority who has access to Personal Data does not process it except on instructions from the Controller, unless required to do so by applicable law.

6. SECURITY

Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of the Processing, as well as the risks for the rights and freedoms of natural persons, the Processor shall implement and maintain appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including as appropriate pseudonymisation and encryption, measures to ensure ongoing confidentiality, integrity, availability and resilience, the ability to restore availability and access in a timely manner, and regular testing and evaluation of effectiveness. The measures currently implemented are described in **Annex II**. The Processor may update these measures from time to time, provided the updates do not materially degrade the overall security of the Services.

7. SUB-PROCESSORS

7.1 The Controller grants the Processor general authorisation to engage Sub-processors for the Processing of Personal Data under this DPA. The current list of Sub-processors is published at <https://attest.comply.org/trackingplan/>.

7.2 The Processor shall update the published list at least fifteen (15) days before a new Sub-processor begins processing Personal Data. The Controller may object to the addition on reasonable data-protection grounds within that period by notifying the Processor in writing and describing its reasons. The parties shall then work

in good faith to resolve the objection; if no resolution is found, the Controller may terminate the affected Services.

7.3 The Processor shall impose on each Sub-processor, by written contract, data-protection obligations no less protective than those set out in this DPA, in particular providing sufficient guarantees to implement appropriate technical and organisational measures. Where a Sub-processor fails to fulfil its data-protection obligations, the Processor remains liable to the Controller for the performance of that Sub-processor's obligations, subject to Section 12 (Liability).

8. DATA SUBJECT RIGHTS

8.1 Taking into account the nature of the Processing, the Processor shall assist the Controller by appropriate technical and organisational measures, insofar as this is possible, in fulfilling the Controller's obligation to respond to requests for the exercise of Data Subjects' rights under Data Protection Laws.

8.2 The Processor shall, to the extent legally permitted, promptly notify the Controller of any Data Subject request it receives directly, and the Controller authorises the Processor to redirect such requests to the Controller to respond directly.

8.3 To the extent legally permitted, the Controller shall be responsible for any reasonable costs arising from assistance that goes beyond the standard functionality of the Services.

9. PERSONAL DATA BREACH

9.1 The Processor shall notify the Controller without undue delay, and in any event within seventy-two (72) hours, after becoming aware of a Personal Data Breach affecting the Controller's Personal Data. The notification shall include, insofar as available, the information required by Article 33(3) GDPR: the nature of the breach, the categories and approximate number of Data Subjects and records concerned, the likely consequences, the measures taken or proposed to address the breach, and a point of contact.

9.2 The Processor shall cooperate with the Controller in investigating and remediating the breach and shall assist the Controller in fulfilling its notification obligations to Supervisory Authorities and Data Subjects under Articles 33 and 34 GDPR and equivalent provisions of other Data Protection Laws.

9.3 The Processor's notification of a Personal Data Breach is not an acknowledgement of fault or liability.

10. IMPACT ASSESSMENTS AND PRIOR CONSULTATION

Taking into account the nature of the Processing and the information available to it, the Processor shall assist the Controller in ensuring compliance with the Controller's obligations to carry out data protection impact assessments and, where required, to consult the competent Supervisory Authority prior to processing, under Articles 35 and 36 GDPR and equivalent provisions of other Data Protection Laws, insofar as such obligations relate to the Processing under this DPA.

11. AUDIT AND INFORMATION RIGHTS

11.1 The Processor shall make available to the Controller information reasonably necessary to demonstrate compliance with the obligations laid down in Article 28 GDPR and this DPA, including security documentation,

security-testing summaries, the Sub-processor list, and responses to reasonable written security questionnaires.

11.2 The Controller (or an auditor mandated by it that is not a competitor of the Processor) may conduct audits, including inspections, no more than once in any twelve (12) month period, upon at least thirty (30) days' prior written notice, during normal business hours, subject to appropriate confidentiality undertakings and with minimal disruption to the Processor's operations. Each party bears its own costs of an audit. Audits may be conducted more frequently where a Personal Data Breach affecting the Controller's Personal Data has occurred or where required by a Supervisory Authority.

11.3 This Section also implements the Controller's right under the CCPA to take reasonable and appropriate steps to help ensure that the Processor uses Personal Data in a manner consistent with the Controller's obligations.

12. LIABILITY

The liability of each party under or in connection with this DPA is subject to the limitations and exclusions of liability set out in the Terms of Service, which apply to this DPA as if set out in full herein.

13. CCPA AND US STATE PRIVACY LAWS

To the extent the CCPA or other US state privacy laws apply to the Processing, the Processor, acting as a service provider or processor:

- (a) shall not sell or share Personal Data;
- (b) shall not retain, use or disclose Personal Data for any purpose other than the business purposes specified in this DPA and the Terms of Service, or outside the direct business relationship between the parties, except as permitted by Data Protection Laws;
- (c) shall not combine Personal Data received from the Controller with personal information it receives from other customers or collects from its own interactions with consumers, except as permitted by the CCPA;
- (d) shall comply with its applicable obligations under the CCPA and provide the same level of privacy protection as required of businesses;
- (e) shall notify the Controller without undue delay if it determines that it can no longer meet its obligations under the CCPA or other applicable US state privacy laws;
- (f) grants the Controller the right, upon reasonable notice, to take reasonable and appropriate steps to stop and remediate any unauthorised use of Personal Data; and
- (g) certifies that it understands and will comply with the restrictions in this Section.

The Processing instructions set out in this DPA are binding on the Processor as contemplated by applicable US state privacy laws.

14. INTERNATIONAL TRANSFERS

14.1 The Processing locations for the Services are described in Annex I; Personal Data is processed and stored within the European Union.

14.2 Neither party shall transfer Personal Data originating in the EEA or the UK to a country not covered by an adequacy decision unless appropriate safeguards under Article 46 GDPR (or the UK equivalent) are in place. In the absence of another agreed safeguard, the applicable safeguard shall be the European Commission's Standard Contractual Clauses (Implementing Decision (EU) 2021/914, or any successor), in the module corresponding to the parties' roles, supplemented where required — and, for transfers subject to the UK GDPR, the ICO's International Data Transfer Addendum or Agreement. The annexes to those clauses shall be completed using the information in Annex I and Annex II of this DPA.

15. TERM, TERMINATION AND DELETION

15.1 This DPA takes effect on the effective date of the Terms of Service (or, if later, the date the Controller accepts this DPA) and continues for as long as the Processor processes Personal Data on behalf of the Controller.

15.2 During the term, stored analytics payload data is automatically and irreversibly deleted under the Processor's retention policy (90-day time-to-live), as described in Annex I; the Controller may request earlier deletion at any time.

15.3 Upon termination or expiry of the Terms of Service, the Controller may export its configurations, measurement plans and learned data specifications in standard formats (JSON/CSV) free of charge using the Processor's standard export tools. Stored analytics payloads are not separately returned; they are deleted under the retention policy. The Processor shall securely delete all remaining Personal Data within ninety (90) days of termination, including copies in backups, unless applicable law requires storage of the Personal Data, in which case the retained data shall be isolated and protected. The Processor shall confirm deletion in writing upon request.

15.4 The obligations in Sections 5 (Confidentiality), 12 (Liability), 15 (Deletion) and any provisions that by their nature should survive shall survive termination of this DPA.

16. GENERAL PROVISIONS

16.1 **Order of precedence.** In the event of a conflict between this DPA and the Terms of Service, this DPA prevails with respect to the parties' data-protection obligations; the limitations and exclusions of liability in the Terms of Service remain unaffected (Section 12).

16.2 **Amendments.** This DPA may only be amended in writing agreed by both parties.

16.3 **Severability.** If any provision of this DPA is held invalid or unenforceable, the remainder shall remain in full force.

17. GOVERNING LAW AND JURISDICTION

This DPA is governed by the laws of Spain, without prejudice to the mandatory application of the Data Protection Laws. The parties submit any dispute arising out of or in connection with this DPA to the exclusive jurisdiction of the Courts and Tribunals of the city of Madrid (Spain). The Agencia Española de Protección de Datos (AEPD) is the competent Supervisory Authority for GDPR matters concerning the Processor, without prejudice to the competence of any other Supervisory Authority under Data Protection Laws.

SIGNED BY THE PARTIES

**FOR AND ON BEHALF OF THE
CONTROLLER**

SIGNATURE

NAME

TITLE

DATE

**FOR AND ON BEHALF OF
TRACKINGPLAN EUROPE S.L.**

SIGNATURE

NAME

TITLE

DATE

ANNEX I — DESCRIPTION OF PROCESSING

1. Subject matter and duration. The Processing of Personal Data necessary to provide the Services under the Terms of Service, for the duration of the Terms of Service and until deletion in accordance with Section 15.

2. Nature and purpose. Trackingplan provides analytics quality assurance: its SDK observes the requests the Controller's sites and apps already send to the Controller's third-party analytics vendors, applies client-side masking and anonymisation (enabled by default), and analyses the resulting metadata and limited payload samples to detect anomalies and data-quality issues. Personal Data is processed solely for the provision of the Services.

3. Categories of Personal Data. Technical metadata that may qualify as Personal Data depending on the Controller's tracking configuration: IP addresses; device and browser information (user agent); timestamps and URLs; referrers and UTM parameters; session or user identifiers (if configured by the Controller). Limited samples of analytics payloads, which may contain Personal Data where the Controller already collects it with the monitored third-party tools; client-side masking, enabled by default, filters such data before it reaches the Processor's servers. Account data of the Controller's authorised users (corporate email address and credentials).

4. Special categories of data. None — the Controller warrants that no special categories of data are submitted (Section 2.2).

5. Categories of Data Subjects. End users and visitors of the Controller's monitored sites and apps; the Controller's employees and other authorised users of the Trackingplan panel.

6. Retention. Payload/event data: automatic, irreversible deletion after a 90-day time-to-live (configurable by written agreement); backups: 30 days; earlier deletion available on the Controller's request at any time.

7. Processing locations. All Personal Data processing and storage takes place in the European Union: AWS eu-central-1 (Frankfurt, Germany), ClickHouse Cloud (Frankfurt, Germany) and Microsoft Azure (EUR Data Zone, for AI features). Cloudflare operates at the user edge as a gateway (TLS termination, DDoS and bot protection), forwarding traffic to the EU origin.

8. Sub-processors. The current list is published at <https://attest.comply.org/trackingplan/>.

ANNEX II – TECHNICAL AND ORGANISATIONAL MEASURES

Measures implemented by the Processor in accordance with Article 32 GDPR.

- 1. Encryption.** All Personal Data transmitted over public networks is encrypted in transit using TLS 1.2 or higher. Personal Data at rest is encrypted using AES-256 across databases, object storage, volumes and backups, with keys managed through AWS KMS under least-privilege access policies. Secrets and credentials are stored in managed vaults, never in source code.
- 2. Access control.** Role-based, least-privilege access defined and peer-reviewed as code; multi-factor authentication mandatory for all personnel; individual named accounts; access granted upon documented approval, reviewed quarterly, and revoked immediately upon offboarding; production access is logged.
- 3. Network security.** Layered edge protection (Cloudflare edge network with AWS WAF behind it) providing DDoS and bot mitigation; network segmentation through VPCs with backend services and databases in private subnets not reachable from the internet; production isolated from development and staging environments; hardened hosts (minimal packages, key-based SSH only, automatic security updates).
- 4. Vulnerability management.** Continuous automated vulnerability and dependency scanning integrated into CI/CD; a yearly penetration test by an independent external party; a documented patch-management process (critical patches typically applied within 24–48 hours).
- 5. Logging and monitoring.** Access to Personal Data is logged with user, timestamp and action; audit logs are retained for at least twelve (12) months and protected against tampering; automated monitoring and alerting operate 24/7 with on-call escalation.
- 6. Business continuity and disaster recovery.** Daily encrypted backups retained for 30 days, plus point-in-time recovery on primary data stores; redundant infrastructure across multiple availability zones within the EU region; a documented disaster-recovery plan (RTO 4 hours, RPO 60 minutes) tested at least annually, including backup-restoration verification.
- 7. Personnel.** All employees and contractors are bound by confidentiality obligations surviving termination of their engagement; data-protection and security training at onboarding and at least annually; company-managed, full-disk-encrypted devices; Customer Personal Data is never stored on personnel endpoints.
- 8. Physical security.** The Processor is a remote-first company and operates no physical data-processing facilities of its own. Physical and environmental security of the data centres is provided by its cloud infrastructure providers (AWS, ClickHouse Cloud, Microsoft Azure), which maintain their own certifications (including ISO 27001 and SOC 2) covering physical access controls, surveillance and environmental protections.
- 9. Privacy by design.** Client-side masking of personal data enabled by default before transmission; no cookies, fingerprinting or new identifiers introduced by the Services; per-customer data isolation with no combination of data across customers; automatic deletion under the 90-day time-to-live.
- 10. Testing and review.** The effectiveness of these measures is tested and evaluated at least annually (external penetration test, disaster-recovery test, security-policy review); findings are documented and result in corrective actions where deficiencies are identified.